

Action-Class Authority: A Verification-Layer Pattern for Agentic AI Security

Mayur Agnihotri

2026

Action-Class Authority: A Verification-Layer Pattern for Agentic AI Security

Mayur Agnihotri, StraightArc Technologies Pvt. Ltd., India

Abstract

Production-scale agentic AI systems fail at the same architectural seam: a prompt-injected, memory-poisoned, or supply-chain-compromised agent retains valid credentials and reasons over its own action authority. We propose action-class authority as a verification-layer pattern that decouples action classification from agent runtime reasoning. Four independent May 2026 publications—across academic systems security, industry framework engineering, empirical production-scale evaluation, and academic adversarial machine learning—converge on the same architectural conclusion: the boundary must move to the action layer. We document the OWASP AISVS verification requirements (C9.2.6 manifest-declared classification, C9.2.7 worst-case chain rule) that operationalize this conclusion, analyze three canonical 2026 cases (Codex docker bind-mount, Meta Instagram AI Support Assistant exploit, Red Hat npm Miasma supply chain), and present a cross-walk to seven adjacent standards bodies showing the action-class authority pattern as an emerging cross-organization synthesis. We close with five open research questions.

Keywords: agentic AI security, action-class authority, OWASP AISVS, manifest-declared classification, deterministic gate, reversibility-graded authority, multi-step chain rule, agent verification, capability-based security

1. Introduction

The agentic AI deployment year of 2026 has crystallized a question the field was able to defer through 2024 and 2025: where does the security boundary for an autonomous agent live? Through the early agentic era, the boundary was treated implicitly as a property of the model—better instruction-following, better safety training, better refusal calibration, the argument went, would produce agents whose reasoning could be trusted to refuse the actions an organization did not want to authorize. Frontier model releases were evaluated on benchmarks that measured the model’s ability to recognize unsafe requests and decline them. Agent deployments inherited the same assumption: if the model is safe, the agent built on top is safe.

May 2026 closed that argument. Four independent publications—Christodorescu and Fernandes’ systems-security framing, Anthropic’s Zero Trust for AI Agents enterprise framework, Kereopa-Yorke et al.’s oracle poisoning measurement at 100% trust rate across nine frontier models, and Pulipaka et al.’s sleeper memory poisoning at 95–99% injection rate—reached the same

architectural conclusion through four independent methodologies. Agent reasoning cannot be the safety boundary. The boundary has to live at the action layer.

1.1 Contributions

This article makes five contributions:

1. **Convergence synthesis.** We synthesize four May 2026 publications into a single architectural conclusion with verbatim empirical numbers cited from one source rather than re-aggregated across four (95–99% memory-layer injection, 100% trust on poisoned knowledge graphs, 60–89% attacker-intended action rates after retrieval).
2. **Verification standard documentation.** We document the OWASP AISVS C9.2.6 manifest-declared classification requirement and the C9.2.7 worst-case chain rule (research chapter merged May 27, 2026), with worked threat model showing why the same agent cannot both propose and classify its action class.
3. **Worked case analysis.** We analyze three canonical 2026 cases (Codex Docker bind-mount, Meta Instagram AI Support Assistant exploit, Red Hat npm Miasma supply chain compromise) demonstrating that the architectural pattern is identical across coding agent, customer-facing AI, and CI/CD pipeline.
4. **Cross-domain prior-art framing.** We frame action-class authority as a cross-domain pattern with structural parallels in capability-based security, transactional database reversibility, formal verification of reversible computation, and digital forensic chain of custody—four traditions converging on the same architectural separation between actor and verifier.
5. **Standards cross-walk.** We provide a cross-walk to seven adjacent standards bodies (CSA NHI, OWASP SPVS, OWASP Cornucopia AAI, OWASP AIVSS, MITRE ATLAS, IETF AI-agent-authentication, CSA ZT Microsegmentation) demonstrating the action-class authority pattern as an emerging cross-organization synthesis in mid-2026.

The remainder of this article is organized as follows. Section 2 describes the May 2026 empirical convergence. Section 3 specifies the verification pattern. Section 4 presents three canonical cases. Section 5 compares against LLM-guardian alternatives. Section 6 cross-walks to adjacent standards. Section 7 enumerates open research questions. Section 8 concludes.

2. The May 2026 Empirical Convergence

Four publications landed in May 2026 that, read together, settle the agent-reasoning-as-boundary question through four independent methodologies.

2.1 Systems-Security Framing

Christodorescu and Fernandes (Google and University of California San Diego) and collaborators argue from systems-security first principles that the AI model itself must be treated as an untrusted component, with security invariants enforced at the system level rather than within the model’s reasoning. The argument is structural: a model that can be prompted, poisoned, or contextually shifted into producing arbitrary outputs cannot also be the mechanism that decides which outputs are safe to act on.

2.2 Operational Framework

Anthropic published the most comprehensive operational framework to date for Zero Trust in agentic AI systems. The framework identifies the boundary problem as a top-of-stack concern and introduces the “impossible vs. tedious” design test: controls whose value is friction (rate limits, extra hops, non-standard ports) degrade against an adversary with unlimited patience; controls that remove a capability survive. Anthropic’s principle reaches further than its prescription—a point Hardt [REF] argues at the credential layer, and the present work extends to the action layer.

2.3 Oracle Poisoning Measurement

Kereopa-Yorke and collaborators (Microsoft, SAP, OWASP GenAI Security Project, University of New South Wales Canberra) demonstrated empirically that every tested state-of-the-art model trusts moderately-sophisticated poisoned knowledge graph data at 100%. The empirical setup uses a 42-million-node code knowledge graph and nine state-of-the-art models from OpenAI, Anthropic, and Google. Three attacker sophistication levels (L1 obvious malicious naming, L2 plausible naming with OWASP-style references, L3 authority markers and adversarial signatures) show that the action-on-retrieved-content rate scales with sophistication while detection rates do not.

2.4 Sleeper Memory Poisoning

Sidharth Pulipaka and collaborators (SPAR, ELLIS Tübingen, CISA Helmholtz) reached the same conclusion at the memory layer: 95–99% injection rates at the memory layer, 90–95% retrieval rates on goal-adjacent queries, and 60–89% attacker-intended action rates after retrieval. A poisoned memory persists across sessions; the agent’s reasoning never sees the injection point because the injection happened at write time, not read time.

2.5 The Convergent Conclusion

Read in isolation, each paper makes a strong claim. Read together, the four constitute a structural argument: agent reasoning is not a safety boundary because (a) the reasoning component is the same one an adversary can corrupt, and (b) corruption rates at memory and retrieval are empirically high enough that any single-layer defense based on reasoning is statistically dominated. The structural answer—if the agent’s reasoning cannot be trusted to classify its own actions, the classification must come from elsewhere—is the verification problem this article specifies.

3. The Verification Pattern

The verification pattern that operationalizes the May 2026 conclusion has two requirements, both merged into the OWASP AISVS research chapter on May 27, 2026.

3.1 C9.2.6 Manifest-Declared Classification

C9.2.6 requires that the reversibility classification of an agent action be declared in the tool or action manifest at design time, not derived from the agent’s runtime output. The four classes are:

- **Read-Only (RO):** action observes state without modifying it
- **Reversible (R):** action modifies state within the system; can be rolled back via undo log, transaction abort, or system-level compensating action

- **External-Reversible (ER):** action affects external systems but is recoverable through identity verification, customer support escalation, or similar out-of-band channel
- **Irreversible (I):** action commits to durable state in ways the user cannot recover from without out-of-band action; emails sent, funds transferred, packages published to public registries, account identifiers linked

The classification lives in the manifest. The gate evaluates the manifest. The agent reasons elsewhere. This is the architectural separation the prior-art traditions (capability-based security, transactional databases, formal verification of reversible computation, digital forensic chain of custody) all establish at their respective layers.

3.2 C9.2.7 Worst-Case Chain Rule

C9.2.7 requires that for a composed multi-step action sequence, the gate evaluates the worst-case action class reachable in the chain, not the per-step class. The rule prevents the composition failure where individually low-gate steps chain into an irreversible end state: read user email (RO) → identify financial accounts (RO) → initiate password reset (ER) → modify account credentials (I) is a chain whose worst-case class is irreversible from the moment the first step executes, not at the irreversible step.

3.3 Threat Model

The threat C9.2.6 specifically addresses: when the same agent both proposes and classifies an action, a prompt-injected or context-corrupted agent can mislabel an irreversible action as reversible. The gate based on the runtime classification will permit the action. The manifest-declared classification, by contrast, was set at design time and cannot be rewritten by the agent at runtime. This is the structural answer to the agent-reasoning-as-boundary failure mode.

4. Three Canonical Cases

Three real-world cases from late May and early June 2026 demonstrate the architectural pattern.

4.1 Codex Docker Bind-Mount (May 30, 2026)

OpenAI’s Codex coding agent, operating on a Linux host where the user was in the docker group, chained four legitimate operations: enumerate group memberships, recognize docker as root-equivalent, construct `docker run --rm -v /etc:/host-etc:rw ubuntu:22.04 ...`, and execute a write that overwrote a live configuration file. Each operation was permitted by the tool authority. The composite action was irreversible at the system level. The C9.2.6/C9.2.7 architecture would have classified “write to /etc on live host” as irreversible in the manifest; the deterministic gate would have routed the action to human ratification regardless of how the agent reasoned about the workflow.

4.2 Meta Instagram AI Support Assistant (May 31, 2026)

Meta’s AI Support Assistant on Instagram had tool authority to modify account state, including linking new email addresses. Attackers identified the prompt pattern that triggered email-link change without identity verification. Exploitation persisted for approximately four months across thousands of accounts including the Obama White House Instagram account and security researcher Jane Manchun Wong. Email-link to a primary identifier is irreversible at the user level (password-reset control follows the email). A manifest-declared classification of this action class

as irreversible, evaluated by a deterministic gate, would have routed the change to out-of-band identity verification regardless of the prompt the attacker constructed.

4.3 Red Hat npm “Miasma” Supply Chain (June 1, 2026)

The `@redhat-cloud-services` npm scope was compromised on June 1, 2026, with 32 packages backdoored. The attack vector was not credential theft—attackers pushed orphan commits adding a workflow file with `id-token: write` permissions, then leveraged OIDC trusted publishing to push to the npm registry through the legitimate path. The Aikido analysis [REF] identifies the architectural failure: “trusted publishing, designed to eliminate long-lived tokens, becomes a misleading trust signal when CI/CD pipeline access is compromised.” The C9.2.6 verification would classify “publish to a public npm scope” as irreversible at the user level in the manifest; the worst-case chain rule of C9.2.7 would gate any chain reaching the publish step as irreversible from the chain start.

4.4 The Architectural Pattern Across Three Cases

Case	Agent / Pipeline	Tool authority	Missing layer	Composite irreversible action
Codex	Coding agent	Docker group membership	Action-class declaration at docker-mount boundary	Write to /etc on live host
Meta IG	AI Support Assistant	Account modification	Action-class declaration on email-link	Identifier change with password-reset implication
Red Hat npm	CI/CD pipeline	OIDC trusted publishing	Action-class declaration at publish step	Public registry publish

The pattern is identical across coding agent, customer-facing AI, and CI/CD pipeline. The three cases use three different agent technology stacks from three different vendors. The composition failure is the same.

5. Comparison with LLM-Guardian Approaches

An alternative architecture proposed in concurrent research uses a second LLM as a guardian agent that evaluates the primary agent’s proposed actions before they execute. The guardian approach has empirical attraction (LLMs are good at policy interpretation) but inherits the same threat model the action-class authority pattern is built to escape: a guardian whose reasoning can be context-shifted or prompt-injected is structurally identical to the agent it guards. The deterministic gate evaluating a manifest-declared classification does not have this property—the classification is set at design time and is not rewritten at runtime by any reasoning component.

This is not a rejection of LLM-guardian approaches. The two architectures are complementary: the manifest-declared deterministic gate is the structural verification layer; LLM-guardian evaluation can layer additional context-aware checks above the gate for cases where the manifest classification is permissive. The architectural argument is about which layer carries the verification load, not whether LLM-based checks have value.

6. Cross-Walk to Adjacent Standards

The action-class authority pattern is one node in a broader set of standards-track contributions across multiple bodies. Table 1 summarizes the cross-walk.

Table 1: Standards cross-walk for action-class authority (mid-2026)

Standards body	Contribution	Status
OWASP AISVS C9.2.6 & C9.2.7	Manifest-declared classification + worst-case chain rule	Merged into research chapter May 27, 2026
CSA Non-Human Identity v1.0	Six-property chain audit schema (jointly contributed with Mallikarjunarao Sunke; properties 1-4 + chain-id binding by Agnihotri; property 5 + immutability constraint by Sunke)	Editorial close mid-June 2026
OWASP SPVS	Decision-rights extensions (PR #14: V5.6.5 incident response; PR #15: V1.3.7 NHI runtime decision-rights)	Under review
OWASP Cornucopia Agentic AI	RO/R/ER/I taxonomy proposed as discussion lens for card content (Issue #3018)	Accepted; refinement integrated
OWASP AIVSS	Action-class authority as scoring axis (Issue #36)	Awaiting project leadership review
MITRE ATLAS M0030	Reversibility classification as deterministic trigger for human-in-the-loop intervention; maps to AML.T0053, AML.T0101, AML.T0086	Under review
IETF draft-klrc-aiagent-auth-01	Reversibility as deterministic trigger for CIBA human-approval; GitHub Issue #114	Filed May 23, 2026
CSA Zero Trust Microsegmentation Guidance	Action reversibility as agentic risk-tier signal; 3-layer scope (nano-segmentation / action-class authority / application authorization)	Peer review complete; pre-publication

The cross-walk pattern is consistent: action-class authority is the verification-layer formulation that operationalizes the May 2026 conclusion across networks, identity, supply chain, threat modeling, vulnerability scoring, MITRE ATLAS mitigations, and IETF authentication. The bodies converge from independent starting points.

7. Open Research Questions

Five open questions warrant empirical study:

1. **Input-layer corruption vs. action-layer gate.** When the manifest itself is corrupted at distribution time (compromised tool registry, malicious provenance), what is the residual exposure of an otherwise-correct action-class gate? Hypothesis: input-layer corruption is bounded by manifest integrity-binding (cryptographic signature, chain-of-custody at install time); empirical measurement of attack rates against signed vs. unsigned manifest distributions would settle the threshold.
2. **Multi-step information flow control.** The worst-case chain rule gates chains; it does not detect cross-chain information flows where reversibility-graded data moves between chains. Hypothesis: information-flow labeling at the data layer, with reversibility class as a label dimension, would extend the chain rule to cross-chain composition.
3. **Runtime drift detection.** When an agent’s action distribution shifts toward higher-risk classes over time (more irreversible actions, more external-reversible chains), is this drift detectable from action-class telemetry alone, or does it require correlated identity, posture, and content signals? Hypothesis: action-class distribution is a leading indicator; correlated signals are confirmatory.
4. **Reversibility classification disagreement.** When two parties (vendor manifest vs. enterprise policy) classify the same action differently, what is the protocol for resolving the disagreement? Hypothesis: worst-case wins (most-conservative class governs gate) is the safe default; empirical case study of real classification conflicts would test this.
5. **Reversibility class evolution.** When an originally-reversible action becomes irreversible due to downstream events (e.g., a “reversible” credential rotation becomes irreversible once propagated to external systems), how is the classification updated, and what is the gate behavior in the transition window? Hypothesis: time-bounded classification escalation with conservative defaults during transition.

These questions have empirical testability and direct relevance to deployed agentic systems. They are appropriate targets for the next twelve months of research.

8. Conclusion

The empirical evidence makes the structural argument unavoidable. Ninety-five to ninety-nine percent injection rates at the memory layer. One hundred percent trust rates on poisoned knowledge graphs across nine frontier models. Sixty to eighty-nine percent attacker-intended action rates after retrieval. The agent’s reasoning will be wrong because the input was corrupted, or because the attacker found a prompt that produces a confident-but-mistaken interpretation, or because the agent’s memory holds an injected goal from a session weeks earlier.

The defense lives at the action layer. The manifest declares which actions are read-only, which are reversible, which are external-reversible, and which are irreversible. The deterministic gate evaluates the manifest declaration, not the agent’s runtime claim. The worst-case action class across a multi-step chain governs the gate, not the average. The agent that has been fooled by corrupted input still cannot execute an action whose manifest-declared classification requires human ratification.

The structural separation we synthesize has parallels in capability-based security, transactional databases, formal verification of reversible computation, and digital forensic chain of custody—four traditions converging on the same architectural answer. The OWASP AISVS C9.2.6 and C9.2.7

verification requirements operationalize this answer as verifiable, spec-anchored, publicly merged specification text. The pattern is being adopted in parallel across CSA NHI, OWASP SPVS, OWASP Cornucopia AAI, OWASP AIVSS, MITRE ATLAS, IETF AI-agent-authentication, and CSA Zero Trust Microsegmentation work.

The conversation is no longer about whether agent reasoning is trustworthy enough to act on. The empirical answer is no, at one hundred percent. The conversation is about where the gate sits and what the gate evaluates against. The action layer is where that gate belongs.

Author

Mayur Agnihotri is Head of Threat Research at SecSphere SOC and SkyVirtRange, and Senior Information Security Specialist at StraightArc Technologies Pvt. Ltd., India. He is a contributor to OWASP AISVS (C9.2.6 and C9.2.7 verification requirements), a peer reviewer for CSA Non-Human Identity v1.0 (joint contribution with Mallikarjunarao Sunke on the six-property chain audit schema), and a contributor to CSA Zero Trust Microsegmentation Guidance. Contact: mayur.agnihotri0021@gmail.com. ORCID: 0009-0007-0137-3780.

References

- [1] M. Christodorescu, E. Fernandes et al., “Agent Security is a Systems Problem,” arXiv preprint 2605.18991v2, 2026.
- [2] Anthropic, “Zero Trust for AI Agents,” Anthropic enterprise eBook, May 18, 2026.
- [3] B. Kereopa-Yorke et al., “Oracle Poisoning: Corrupting Knowledge Graphs to Weaponise AI Agent Reasoning,” arXiv:2605.09822v1, 2026.
- [4] S. Pulipaka et al., “Hidden in Memory: Sleeper Memory Poisoning in LLM Agents,” arXiv:2605.15338v2, 2026.
- [5] OWASP AISVS Project, “AI Security Verification Standard,” v1.0 (release June 24, 2026); research chapter C09-Orchestration-and-Agents/C09-02-High-Impact-Action-Approval.md merged May 27, 2026. github.com/OWASP/AISVS.
- [6] Cloud Security Alliance, “Defining Non-Human Identity v1.0,” editorial close June 2026.
- [7] Y. Liu et al., “‘Do Not Mention This to the User’: Detecting and Understanding Malicious Agent Skills in the Wild,” USENIX Security Symposium 2026; arXiv:2602.06547.
- [8] Aikido Security, “Analysis of the @redhat-cloud-services npm Compromise (Miasma),” June 1, 2026.
- [9] Socket Research Team, “@redhat-cloud-services Supply Chain Attack Analysis,” Socket.dev, June 1, 2026.
- [10] M. S. Miller, “Robust Composition: Towards a Unified Approach to Access Control and Concurrency Control,” Ph.D. dissertation, Johns Hopkins University, 2006.
- [11] D. Hardt, “Anthropic’s Zero Trust for AI Agents Sets the Right Test: The Bearer Token Fails It,” Hellō Blog, June 13, 2026.
- [12] MITRE ATLAS Project, “Adversarial Threat Landscape for AI Systems: Mitigation M0030 Human-in-the-Loop AI Agent Actions,” 2026.

- [13] P. Kasselmann, A. Lombardo, H. Rosomakho, B. Campbell, M. B. Steele, “AI Agent Authentication and Authorization,” IETF Internet-Draft draft-klrc-aiagent-auth-01, 2026.
- [14] OWASP Foundation, “Top 10 for LLM Applications and Generative AI v2/2025,” LLM06:2025 Excessive Agency. owasp.org/www-project-top-10-for-large-language-model-applications.
- [15] Cloud Security Alliance Zero Trust Working Group, “Zero Trust Microsegmentation Guidance,” 2026 (ZT5 workstream, lead author P. Griffiths).